EWB COURSES

Assessment 01: Security Foundations

AI-Powered Cybersecurity

Name	Tinglikar Preethi Sudha
Batch / Group	Group A
Assessment	Individual work | 100 marks
Issued	18 October 2026

This report uses only the fictional scenarios and synthetic log evidence supplied in Assessment 01. Interpretations are labelled as likely or possible where the evidence does not prove a conclusion.

Task A — Secure a student account (25 marks)

A1–A2. Risks, assets, CIA impact, controls and limitations

The table identifies five distinct risks in Mira's scenario. CIA means confidentiality (keeping information private), integrity (keeping information accurate and unchanged), and availability (being able to access it when needed).

Risk	Asset	CIA impact	Control	Limitation
Reusing a short password	Email and learning-portal accounts and their data	Confidentiality: if one password is guessed or exposed, both accounts may be accessed. Integrity and availability may also be affected if an attacker changes data or locks Mira out.	Use a long, unique password for each account; a password manager can help create and store unique passwords.	A strong unique password does not stop every phishing attack or malware. The password manager itself must be protected.
Approving unexpected sign-in prompts	Account access, messages, assignments and personal data	Confidentiality: an unapproved person may enter the account. Integrity: they may change profile or coursework information.	Deny unexpected prompts. If they continue, change the password from the official site and report the prompts to IT.	A user may accidentally approve a prompt; prompt approval alone does not prove who initiated the request.
Postponing device updates	Laptop, browser, files and saved sessions	Confidentiality and integrity: known software weaknesses may be exploited. Availability: malware or crashes may stop the laptop working.	Install operating-system and application updates promptly from official update settings.	Updates cannot remove every weakness and sometimes require a restart or may not cover unsupported software.
Keeping the only project copy on one laptop	Project files and coursework	Availability: device loss, damage or ransomware could make the only copy unavailable. Integrity may be affected if files are corrupted.	Keep a separate backup, such as a trusted cloud backup or external drive, and test that files can be restored.	A backup that stays connected or is never tested may also be lost, corrupted or encrypted.
Friend uses laptop while Mira is signed in	Open accounts, private files and saved credentials	Confidentiality: the friend could see private information. Integrity: files or account settings could be changed. Availability: files could be deleted.	Lock the screen when away, sign out of accounts, and use a separate standard user account for the friend.	A separate account and screen lock reduce risk but do not protect files that Mira deliberately shares or has left accessible.

Priority order

1. Stop approving unexpected sign-in prompts and secure the accounts. This is first because a suspicious sign-in may be happening now. Deny prompts, change any reused password through the official site, and tell IT if prompts continue.

2. Create unique passwords for email and the learning portal and enable multi-factor authentication (MFA) where available. This reduces the chance that one exposed password gives access to both accounts. MFA is helpful but not perfect.

3. Make and test a separate backup of the project files. This protects coursework from laptop failure, loss or accidental deletion. Then install pending updates and improve laptop access controls.

A3. Authentication versus authorisation

Authentication checks who a user is, for example when Mira signs in to the learning portal with her password and a second factor. Authorisation decides what that authenticated user is allowed to do, such as view course materials, submit her own assignment or access a teacher-only grade-management page. Passing authentication does not automatically give permission to perform every action.

Task B — Analyse a suspicious message (25 marks)

B1. Warning signs

Evidence phrase	Why it needs scrutiny
“From: Scholarship Desk — awards@campus-awards.example”	The sender address is not the college’s stated normal domain, campus.example. A display name can be chosen by a sender, so the name alone is not proof of identity.
“Reply-To: help@personal-awards.example”	The reply address differs from the From address and uses another domain. This mismatch needs independent verification.
“FINAL WARNING” and “expires in 20 minutes”	Urgent threats and a very short deadline pressure the student to act before checking the message.
“enter your college password and OTP”	The message asks for both a password and a one-time passcode. These are secrets and should not be provided through a link in an unexpected message.
“Do not contact the college office” and “send a photo of your identity card”	Discouraging independent checking is suspicious. Requesting an identity-card photo creates a risk of identity-data exposure.

B2. Safe verification process

1. Do not click the link, reply, provide a password or OTP, or send an identity-card photo. 2. Open the college portal by typing its known official address or using a saved trusted bookmark. Alternatively, use a phone number or email address from an official college website or student handbook obtained separately—not from this message. 3. Ask the scholarship or IT office whether the notice is genuine. 4. Report the message using the college’s official reporting process and follow its instructions.

HTTPS encrypts the connection between a browser and a website, but it does not prove that the site belongs to the college or that its content is honest. A familiar display name can be imitated. The supplied .example addresses are fictional training examples, so this exercise does not prove that a real sender or website is malicious.

B3. If a student already entered a password and OTP

1. Immediately open the real college portal using its independently verified address and change the compromised password. If it was reused elsewhere, change it on those accounts too, starting with email. Do not send the old or new password or OTP to anyone. 2. Contact the official college IT/security team using a trusted contact route; explain that the password and OTP were entered and provide the time and message details, but not the secrets. 3. Ask IT to revoke active sessions, check recovery details and registered MFA methods, and block unauthorised access where possible. 4. Check recent sign-ins, sent messages, account changes and scholarship records. Preserve the message and relevant timestamps for investigation; do not delete logs or evidence. 5. Watch for further prompts or account recovery messages and report them.

B4. What cannot be established

From the message text alone, we cannot establish who actually sent it or whether a real account or website was compromised. Helpful additional evidence would include full email headers, authenticated mail-routing results, official college confirmation, and a controlled security review of the actual URL by authorised staff. Do not visit the supplied sample address for this assessment.

Task C — Triage a sign-in alert (25 marks)

C1. Four-point timeline: observed facts and interpretation

Time (IST, 18 Oct 2026)	Observed evidence	Interpretation (not proven)
09:00–09:01	Password succeeded and MFA was approved from 192.0.2.10, which the lab notes identify as the usual classroom egress.	This appears consistent with a normal sign-in, but the logs alone do not prove who used the account.
10:14–10:15	Two password attempts from 198.51.100.23 failed.	Could be typing errors, repeated attempts by the user, or an unauthorised attempt. The IP alone does not identify a person.
10:16–10:17	A password attempt from the same IP succeeded; the next MFA event was denied.	The password was accepted, but the denied MFA indicates the sign-in was not yet fully approved. The log does not show how the password was obtained.
10:18–10:20	MFA was approved, then a session was created from the sequence associated with 198.51.100.23. Student07 says they did not sign in and approved a prompt to stop repeated requests.	The user's statement and sequence raise concern that an unexpected prompt was approved and access may have followed. More evidence is needed to confirm the session's actor and activity.

C2. Likely explanation, alternative and additional checks

Likely explanation: someone other than student07 may have used a valid password and then obtained MFA approval through the unexpected prompt. The student says they approved the prompt to stop repeated requests, and a session was created shortly afterwards. This is a plausible account-compromise scenario, not proof of the attacker's identity.

Alternative explanation: student07 or an authorised person may have initiated the sign-in through an unfamiliar network or device, while the user's recollection or timing is incomplete. The IP difference alone cannot decide between these explanations.

Two useful checks: (1) Review identity-provider audit records for device/browser details, session/token identifiers, MFA method and exact event correlation. (2) Ask student07 to confirm recent devices, network/VPN use and account activity, then compare this with endpoint and application logs for actions after 10:20. The checks should be performed by authorised IT staff and documented.

C3. Three prioritised response actions for authorised IT

1. Protect the account immediately: contact the user through a trusted channel, reset the password, revoke active sessions/tokens, and review or reset MFA methods and recovery settings as appropriate. Preserve evidence before changes where practical, without delaying urgent containment.

2. Preserve and correlate evidence: export the relevant authentication, MFA and session logs with timestamps and time zone; record the source and collection time; retain them securely and avoid deleting or altering the originals. Collect related endpoint/application logs under the organisation's process.

3. Investigate and monitor: check for unfamiliar devices, account changes, data access, messages or actions after session creation; block suspicious sessions or indicators where supported; inform the appropriate security lead and keep monitoring for repeated attempts.

C4. Incident summary (82 words)

On 18 October 2026, student07 had a successful password and MFA sign-in from the usual classroom egress at 09:00–09:01. At 10:14–10:15, two password attempts from 198.51.100.23 failed; a password attempt then succeeded at 10:16. MFA was denied at 10:17 and approved at 10:18, followed by session creation at 10:20. Student07 says they did not sign in and approved a prompt to stop repeated requests. Possible account compromise needs urgent checking, but the IP does not identify a person. IT should protect the account and preserve correlated logs.

Task D — Review an AI security answer (25 marks)

D1. Five unsafe or unsupported claims/actions and corrections

AI output claim/action	Correction and reason
“The email is safe because it uses HTTPS.”	Incorrect. HTTPS encrypts a connection but does not prove the website is genuine or the message trustworthy. Verify through the independently obtained official college portal or contact.
“The sign-in logs prove that the person using 198.51.100.23 stole the password.”	Unsupported. The logs show failed password attempts, a later success, MFA events and session creation. They do not identify a person or prove how the password was obtained. An IP address is not a person’s identity.
“MFA prevents every account compromise.”	Incorrect. MFA adds a layer of protection, but a user may approve an unexpected prompt or an attacker may exploit other weaknesses. Unexpected prompts should be denied and reported.
“Delete the suspicious logs.”	Unsafe. Logs are evidence needed to establish what happened. Preserve relevant records, timestamps and context; only authorised staff should collect and handle them under the incident process.
“Send the student’s password to support so they can test it.”	Unsafe. Passwords and OTPs must not be shared with support or an AI tool. Use an official password reset and let authorised IT staff investigate through logs and approved procedures.

D2. Safer AI analysis prompt

“Analyse only the fictional phishing-message evidence and synthetic sign-in logs supplied below. List observed facts separately from interpretations and assumptions. Identify warning signs, explain what the logs do and do not establish, and give safe, prioritised response steps. Do not identify a person from an IP address, claim certainty where evidence is incomplete, visit any sample URL, or request passwords, OTPs, identity documents or other secrets. Recommend evidence preservation and independent verification. State what additional authorised checks could reduce uncertainty. Do not invent facts or sources.”

D3. Corrected security advice (126 words)

Treat the scholarship message as suspicious because it uses urgency, asks for a college password and OTP, gives a different reply address, discourages contacting the college, and requests an identity-card photo. Do not click its link or reply with sensitive information. Verify the notice through the college portal or an official contact found independently. HTTPS alone and a familiar display name do not prove legitimacy. The sign-in logs show failed password attempts, a later password success, an MFA denial followed by approval, and session creation. Student07’s statement makes an unexpected approval a concern, but the logs do not identify a person or prove how the password was obtained. Contact authorised IT promptly, reset the password, revoke sessions as advised, review account activity, and preserve relevant logs and message details. Never share passwords or OTPs.

D4. AI-use declaration and evidence/reference notes

AI-use declaration: ChatGPT was used to help draft and organise the answers in this report in simple English. The supplied fictional message and synthetic logs were used as the evidence. The student should read, verify and edit the report so it reflects their own understanding before submission. No real password, OTP or personal account data was supplied.

Evidence note 1 — Assessment 01, Tasks B and C: The message fields and quoted wording are fictional evidence supplied on page 2. The sign-in timeline and student statement are synthetic evidence on page 3. This report distinguishes these observed details from possible explanations.

Reference note 2 — CISA, Secure Our World: General guidance on strong passwords, MFA, recognising phishing and reporting suspicious activity. https://www.cisa.gov/secure-our-world

Reference note 3 — NIST, Artificial Intelligence Risk Management Framework: Generative AI Profile (AI 600-1): Supports checking AI output critically because generative AI can produce inaccurate or unsupported content. https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf

Before submission: confirm the name and group details, review every answer, and save using the required filename format.